Daryadarcy App
Технический отчёт
для независимого аудита

Дата: 28.08.2026
Владелец: ИП Левина Дарья Сергеевна
Production: https://daryadarcy.com
Версия приложения: 1.0.0
Документ не содержит секретов, паролей и персональных данных пользователей.

1. Резюме

Daryadarcy - PWA/мобильное приложение бренда Darya Darcy: лента, видео, клуб по подписке, библиотека, магазин, интерактив (квиз). Backend на Node.js + tRPC, БД MySQL 8 (Timeweb), медиа - Timeweb S3, хостинг - VPS Timeweb (Россия).

Отдельного staging-окружения нет. Автотесты: 30 (Vitest). В августе 2026 выполнена оптимизация изображений (~192 МБ экономии на S3, ~85 МБ в бандле приложения).

2. Окружения и роли

Окружение	URL / назначение
Production	daryadarcy.com - PWA + API
Локально	localhost:8081 (web), localhost:3000 (API)
Staging	Не развёрнут

Роли пользователей

- Гость - лента, видео, магазин, часть библиотеки
- Пользователь (users.role=user) - профиль, лайки, вход SMS/email
- Подписчик клуба - club_subscriptions активна - контент клуба, pen pals
- Администратор (role=admin) - CRUD контента, модерация

3. Технологический стек

- Клиент: React Native 0.81, Expo 54, Expo Router, TypeScript
- Web: Expo export (PWA), React Native Web
- API: Node.js, Express, tRPC 11, Zod, superjson
- БД: MySQL 8 utf8mb4, Drizzle ORM
- Файлы: Timeweb S3 (s3.twcstorage.ru)
- Auth: JWT cookie/Bearer, SMS.ru OTP, email+password (scrypt)
- Платежи: Prodamus (клуб, цифровые товары)
- Деплой: nginx + PM2 на VPS Timeweb

4. Персональные данные - поля профиля

Поле	Статус
Имя / ник (name)	Да - одно поле, отдельного псевдонима нет
Телефон	Да - вход по SMS, уникальный
Email	Да - вход, оплата, связь
Пол (gender)	Да - female / male
Аватар	Да - URL на S3
Дата рождения	Нет
Город в профиле	Нет - только в Pen pals (план: ФИО)
Пароль	Хеш scrypt - только email-вход

Дополнительные данные

- Pen pals: интересы (2-3), почтовый адрес, поле city (план: ФИО)
- Квиз: результат локально (AsyncStorage), не на сервере
- Лайки, сохранения, комментарии - привязка к userId
- Push-токен (Expo) - только native, web - заглушка

5. Авторизация

Способ	Сервис
SMS OTP	SMS.ru (sms.ru/sms/send), код SHA-256, TTL 5 мин
Email + пароль	Встроенная (/api/auth/register, /login)

Сторонних OAuth (Auth0, Firebase Auth, Яндекс ID) нет.

6. Инфраструктура и размещение данных

Компонент	Провайдер / страна
Backend API	Timeweb VPS, Россия
База данных	Timeweb MySQL 8, Россия
Изображения	Timeweb S3, bucket daryadarcy-s3
Резервные копии	Не автоматизированы в коде; уточнить у Timeweb

Точный дата-центр (город) - по договору Timeweb.

7. Аналитика и сторонние SDK

Сервис	Используется
Яндекс Метрика	Нет
Google Analytics	Нет
Sentry	Нет
Firebase	Нет
Expo	Да - фреймворк, не аналитика
Expo Push	iOS/Android; web - нет
Google Fonts	Да - EB Garamond, Playfair

8. Сроки хранения и удаление

- Удаление аккаунта по запросу: 14 рабочих дней (вручную, daryadarcy19@gmail.com)
- После отмены подписки: 30 дней, затем удаление (политика)
- Pen pals "Удалить анкету": деактивация сразу
- Автоудаление по таймеру в коде: не реализовано
- Данные банковских карт не хранятся - Prodamus
- club_payments / shop_purchases: orderId, email, сумма, статус
- Pen pals: 90 дней / 30 дней после обмена - запланировано, не внедрено

9. Безопасность и доступ специалистов

- Журнал admin-действий (audit log): не реализован - только PM2 logs
- 2FA доступа к БД: не настроена

- Admin: role=admin + JWT-сессия
- NDA специалистов: организационный документ - приложить отдельно

10. Почтовое отделение (Pen Pals)

Раздел для подписчиков клуба - подбор друга по переписке.

Текущая механика

- Автоматический подбор до 2 кандидатов по общим интересам (>=1)
- Полный почтовый адрес показывается сразу - без взаимного подтверждения
- Не пара 1:1 - односторонний показ кандидатов
- Отзыв заявки: кнопка "Удалить анкету" или email в поддержку

Запланированные доработки (по аудиту)

- Этап "Подтвердить обмен адресами" - адрес после 2 подтверждений
- Поле "Город" -> "ФИО"
- Отдельные юр. документы: согласие на передачу адреса, правила сервиса
- Срок хранения: до 90 дней до матча, 30 дней после обмена

11. Цифровые товары (магазин)

- Товары: digital-1 (пособие по фото), digital-2 (мастер-класс)
- Оплата: Prodamus, требуется вход + email в профиле
- После оплаты: запись shop_purchases, UI "Оплата получена"
- Файл на email: ручная отправка - автодоставки нет
- Раздел "Мои покупки" / скачивание в приложении: нет
- Без аккаунта (старый /api/pay/) - только email в Prodamus, в app не видно

12. Юридические документы

- Есть: Политика конфиденциальности + Условия (app/privacy, public/privacy.html)
- Нужно добавить: публичная оферта, политика возврата, согласие на ПДн, реквизиты ИП
- Pen pals: отдельные документы - в работе

13. Оптимизация производительности (август 2026)

- S3: 145 файлов оптимизировано, ~192 МБ экономии
- Бумажная текстура: 5.7 МБ -> 230 КБ
- Локальный бандл: PNG->WebP, JPG пересжатие (~120->~35 МБ assets)
- Скрипты: npm run optimize:s3, npm run optimize:assets

14. API (кратко)

tRPC: https://daryadarcy.com/api/trpc/ - auth, profile, feed, videos, club, admin, articles, shop, penPals, notifications.

Health: GET /api/health. REST: /api/auth/*, /api/prodamus/*, /api/pay/:id

15. База данных (таблицы без PII)

users, posts, post_media, tags, likes, saved_posts, videos, articles, club_subscriptions, club_payments,

shop_purchases, post_comments, pen_pal_profiles, pen_pal_shown, push_tokens, sms_codes.

Схема: drizzle/schema.ts, миграции drizzle/*.sql

16. Интеграции

- Timeweb MySQL, S3, VPS
- SMS.ru - OTP
- Prodamus - платежи
- YouTube - превью видео
- Expo Push - native уведомления

17. Автотесты

- __tests__/regression.test.ts - 18 тестов UI
- __tests__/quiz-data.test.ts - 12 тестов
- npm run verify - 30 тестов перед деплоем

18. Известные ограничения

- Нет staging-домена
- Нет E2E (Playwright/Detox)
- Pen pals без mutual confirm
- Цифровые товары - без auto-delivery
- Нет audit log / 2FA БД

19. Правила аудита на production

Разрешено

- Просмотр публичных разделов, UI/UX, responsive
- Тестовые аккаунты (не owner admin)
- npm run smoke

Запрещено

- Редактирование реальных постов без согласования
- Нагрузочное тестирование, реальные платежи
- Доступ к .env, SSH, БД, S3-ключам
- Экспорт персональных данных

20. Комплект поставки

- Архив исходников: daryadarcy_app_backup_YYYY-MM-DD.zip (~230 МБ)
- docs/ - AUDIT-PACKAGE, API, DATABASE-SCHEMA, INTEGRATIONS, KNOWN-ISSUES
- README.md, .env.example
- Не входит: .env, пароли, PII, полные server logs
- Тестовые аккаунты и NDA - отдельно

21. Контакты

Администратор: ИП Левина Дарья Сергеевна

Email: daryadarcy19@gmail.com

Сайт: https://daryadarcy.com

Технические вопросы аудита - к разработчику проекта.